PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Restrictions logicielles Windows

03-550 ANSSI - Recommandations pour la mise en œuvre d'une politique de restrictions logicielles sous Windows — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. AppLocker permet de cibler un utilisateur ou un groupe précis contrairement aux SRP qui affectent tous les utilisateurs indifféremment.
2. La règle de type Empreinte offre le meilleur niveau de sécurité mais impose une maintenance plus lourde lors des mises à jour.
3. Le mode audit permet de simuler l'application d'une politique sans bloquer l'exécution des programmes.

Mécanismes de restrictions logicielles

Notion	À retenir
Intérêt des restrictions	Protection contre programmes malveillants (connus/inconnus), logiciels indésirables ou sans licence ; peu d'impact sur les performances ou l'utilisateur sur les **postes de travail**.
Choix AppLocker/SRP	Privilégier **AppLocker** (éditions **Entreprise** Windows 7 à 10 / serveurs) pour cibler des **utilisateurs précis**, contrairement aux **SRP** (règles indifférenciées).
Fonctionnement règles	Évaluation : **Refuser** puis **Autoriser**. Tout programme sans règle **Autoriser** est bloqué par **refus implicite**. Privilégier les règles **Autoriser** pour la lisibilité.

Types de règles AppLocker

Type de règle	À retenir
Chemin d'accès	Répertoire et sous-répertoires ; inefficace si un dossier autorisé est **accessible en écriture** aux non-privilégiés.
Éditeur (signature)	À privilégier si **certificats** et **autorités de certification** sont de confiance.
Empreinte (SHA-256)	**Meilleur niveau de sécurité**, au prix d'une **maintenance plus lourde** à chaque mise à jour.

Mise en œuvre de la stratégie de restrictions

Notion	À retenir
Démarche préalable	Réaliser un **inventaire** des applications. Utiliser l'**audit d'AppLocker** pour les inconnues. Configurer `AppIdSvc` en **démarrage automatique** avec des comptes **non privilégiés**.
Règles par défaut	Renforcer les **3 règles par défaut** (C:\Windows, C:\Program Files, administrateurs). C:\Windows : lister les sous-répertoires inscriptibles en exception ou passer à une règle **Éditeur** (signés **Microsoft**) ; C:\Program Files : **autorisations explicites** par application ; **scripts** depuis C:\Windows totalement refusés (sauf signés ou par empreinte).
Bibliothèques et applications	Activer les règles **DLL** (risques de contournement). Créer des règles **Éditeur** dédiées pour les **applications universelles**, avec exceptions pour les applications Microsoft non désirées.
Test et maintien	Tester en **mode audit** via la collecte centralisée et `Get-AppLockerFileInformation`. Effectuer un **déploiement progressif** et une **qualification** des nouveaux logiciels/mises à jour sur systèmes de référence.

Vecteurs de contournement des restrictions

Notion	À retenir
Exécutables de contournement	Appliquer une exception de type **Éditeur** interdisant `regsvr32.exe` et `InstallUtil.exe` (Microsoft Framework 4.0) pour les utilisateurs non privilégiés.
Autres vecteurs	Neutraliser les **ActiveX**, restreindre les **codes interprétés** (macros signées), désactiver **NTVDM** et évaluer les modules d'extension/paramètres d'appel des programmes autorisés.

Pièges et confusions

- ⚠ Confondre l'activation d'AppLocker sans règle définie avec un fonctionnement normal (cela bloque tout, y compris les exécutables système).
- ⚠ Croire qu'un dossier autorisé par AppLocker est sécurisé même s'il est accessible en écriture par des comptes non privilégiés.
- ⚠ Penser que les règles AppLocker contrôlent le programme une fois lancé : elles ne portent que sur son lancement, pas sur ses paramètres d'appel ni ses modules d'extension.

Sigles et définitions

SRP	Mécanisme historique permettant de restreindre l'exécution de programmes par liste blanche pour tous les utilisateurs.
AppLocker	Évolution des SRP permettant de cibler un utilisateur ou un groupe précis, disponible sur éditions Entreprise.
Règle de type Chemin d'accès	Autorise ou refuse l'exécution de fichiers situés dans un répertoire et ses sous-répertoires.
Règle de type Éditeur	Autorise l'exécution des fichiers signés par un éditeur donné.
Règle de type Empreinte	N'autorise que le fichier correspondant exactement à une empreinte cryptographique SHA-256 donnée.

Auto-test

1. Quelle est la conséquence si AppLocker est activé sans aucune règle définie ?
2. Quel type de règle offre le meilleur niveau de sécurité ?
3. Sur quelles éditions de Windows AppLocker est-il disponible ?
4. Comment s'appelle la commande pour analyser les blocages avec la collecte centralisée ?
5. Que permet de faire le mode audit ?

Réponses : **1.** L'exécution de tous les programmes est bloquée, y compris les exécutables système. · **2.** La règle de type Empreinte. · **3.** Les éditions Entreprise ou équivalentes. · **4.** Get-AppLockerFileInformation. · **5.** Simuler l'application d'une politique sans bloquer l'exécution des programmes.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.